

Sentra / SecureRAG - Month 1 Progress Report

Author: Rohnit | **Date:** 18 September 2026 | **Phase:** Month 1 - Core RAG + Access Control

1. Overview

This report summarizes all work completed during Month 1 of Sentra, a solo major project evaluating whether retrieval-layer authorization (enforced via Postgres Row-Level Security) reduces sensitive-information leakage compared to conventional application-layer access control in a role-gated RAG system. Month 1 covered project setup, corpus and ingestion, the three-model access-control implementation (A: none, B: application-layer, C: retrieval-layer), and a three-part test matrix validating Model C across 85 total test cases.

Detail	Value
Project	Sentra / SecureRAG
Weeks Covered	Week 1 to Week 4 of 12 (plus buffer)
Phase	Month 1 - Core RAG + Access Control
Author	Rohnit
Report Date	September 2026
Repository	github.com/flash-sagittario/sentra
Active Branch	main (all Month 1 PRs merged from dev)
Milestone Due Date	30 September 2026

2. Work Completed

2.1 Week 1 - Foundation

- Backend and frontend skeleton confirmed running locally.
- Supabase project and initial schema created (documents, chunks tables).
- Formal Scoping Document and Weekly Development Plan produced as Word documents.

2.2 Week 2-3 - Corpus, Ingestion, and Access Models

- Corpus generation complete: 30 synthetic documents (29 PDF, 1 txt) across 4 roles for a fictional company, generated via Gemini.
- Corpus manifest CSV created (filename, doc_id, department, sensitivity_level, title).
- Ingestion pipeline built and verified: 30 documents / 93 chunks in Supabase, all embeddings at 768 dimensions, role values correct, no duplicates.
- Model A (no access control), Model B (application-layer filtering), and Model C (retrieval-layer RLS) implemented behind a single ACCESS_MODEL env flag in the /query endpoint.
- Initial three-model spot check against the Employee test account: Model A leaked hr/admin chunks as expected; Models B and C both correctly restricted to employee/public chunks.
- Schema drift resolved: sensitivity_level column dropped from the live Supabase schema after confirming (Scoping Document Section 5A/5D) it has no defined role in the RLS design, which is purely role/department based.

2.3 Week 4 - Test Matrix Validation

- **W4.1:** Initial 4-role x 4-query test matrix against Model C found a critical bug: an undocumented RLS clause granted admin unconditional access, leaking hr/legal chunks on all 4 queries (12/16 passed). Fixed via ALTER POLICY; retest passed 16/16.
- **W4.2:** Expanded matrix to 48 cases (every role x every domain, with paraphrased query variants). All 48 passed, confirming enforcement holds across phrasing, not just the original test wording.
- **W4.3:** Tested 21 edge cases across two categories: off-topic queries with no corpus match (correctly fell back to public-tier content, no hallucination) and direct cross-domain asks (correctly filtered with zero leaked roles). All 21 passed.
- **W4.4:** Buffer and slippage-absorption week. No Month 1 tasks were outstanding, so no slippage to absorb.
- **W4.5:** Month 1 learning synthesis note written, covering the retrieval-layer vs. application-layer argument, the admin RLS bypass bug, and the schema drift decision.

3. Test Evidence

All Model C access-control validation for Month 1 is captured across three merged pull requests, totalling 85 test cases with a 100% pass rate after the Week 4 fix.

PR	Scope	Result
#68	W4.1 - admin RLS bypass fix, closes #21	16 / 16 passed
#69	W4.2 - Section 5A access matrix, closes #22	48 / 48 passed
#70	W4.3 - no-content vs. access-denied, closes #23	21 / 21 passed